Care Access Navigator

Compliance 1 — Task 1: Compliance Fundamentals

Applicable regulations, compliance requirements analysis with business process mapping, compliance program plan, and two documented controls

Prepared by:	Akhila Chennamaneni, GRC Analyst (author)
Organization:	HealthLine Regional Medical Center
Scope:	Care Access Navigator (CAN)
Frameworks:	HIPAA (Privacy, Security and Breach Notification Rules, as amended by HITECH) and PCI DSS v4.0.1
Date:	October 13, 2026

Purpose

This document applies two major regulatory frameworks to Care Access Navigator, the identity-and-access platform built for HealthLine Regional Medical Center throughout the capstone. It identifies which regulations apply and why, defines the regulatory vocabulary used across the compliance program, maps the organization's business processes to concrete requirements, sets out a compliance program plan with roles and a timeline, and documents two controls with implementation and testing procedures. Where a control already exists in the capstone (Keycloak RBAC, Azure governance, monitoring), the evidence is referenced rather than invented.

Organization profile

Attribute	Care Access Navigator / HealthLine
Organization	HealthLine Regional Medical Center — a fictional regional, not-for-profit acute-care hospital and outpatient network (assumed to operate in New York State) used as the capstone scenario
Platform in scope	Care Access Navigator (CAN): the identity and access layer and connected applications that let workforce members and vendors reach clinical, billing and HR systems
Applications	EHR Simulator (synthetic ePHI), Patient Portal, Billing App (patient balances and co-pay card payments), HR App, Keycloak identity provider federated with Microsoft Entra ID
Workforce roles (RBAC)	Clinician, Nurse, Billing, HR, IT Support, Security Analyst, Vendor
Hosting	Containerised apps and Keycloak; Microsoft Azure for identity federation, governance policy, monitoring and security tooling (CloudSec1 Criteria 3–6)
Sensitive data	Electronic protected health information (ePHI); payment card data at the point of co-pay collection; workforce PII

1. Applicable Regulations

Candidate frameworks were screened against HealthLine's legal status, data and business activities. Two frameworks apply directly and form the basis of this program; the others were considered and documented as out of scope so the decision can be revisited if the business changes.

Framework	Type	Status	Applicability rationale
HIPAA / HITECH	Federal law (45 CFR Parts 160 and 164)	Applies	HealthLine is a HIPAA covered entity (health-care provider that bills electronically); CAN creates, receives and transmits ePHI.
PCI DSS v4.0.1	Contractual standard (card brands via acquiring bank)	Applies	The Billing App accepts patient co-pay and balance payments by card; any merchant that stores, processes or transmits account data must comply.
GDPR	EU regulation	Not applicable	No establishment in the EU and no offering of services to, or monitoring of, people in the EU.
SOX	Federal securities law	Not applicable	Not-for-profit; no publicly traded securities. Internal-control practices are borrowed as good practice only.
42 CFR Part 2	Federal regulation (SUD records)	Not in scope	Assumes no federally assisted substance-use-disorder program feeds CAN; to be re-checked if one is added.

1.1 HIPAA at a glance

Rule	Citation	What it requires of HealthLine / CAN
Privacy Rule	45 CFR 164.500–534	Uses and disclosures of PHI, minimum necessary, patient rights, privacy official, workforce training, sanctions
Security Rule	45 CFR 164.302–318	Administrative, physical and technical safeguards for ePHI; risk analysis; documentation retained 6 years
Breach Notification Rule	45 CFR 164.400–414	Notify individuals, HHS and (if >500 in a state) media after a breach of unsecured PHI
Enforcement Rule	45 CFR 160 Subparts C–E	HHS OCR investigations and tiered civil money penalties (inflation-adjusted annually)

1.2 PCI DSS v4.0.1 at a glance

Goal	Req.	Relevance to CAN
Build and maintain a secure network	1–2	Network security controls around the cardholder data environment (CDE); secure configurations
Protect account data	3–4	Do not store sensitive authentication data; encrypt PAN in transit (4.2.1)
Vulnerability management	5–6	Anti-malware, secure development of the Billing App, patching
Strong access control	7–9	Least-privilege roles (7.2), unique IDs and MFA (8.3, 8.4), physical access

Goal	Req.	Relevance to CAN
Monitor and test networks	10–11	Audit logs, daily review, 12-month retention (10.5.1); scanning, penetration tests
Information security policy	12	Policies, risk analysis, awareness training, incident response (12.10)

Scope decision: CAN reduces PCI scope by never storing card numbers: the Billing App embeds a PCI-validated payment processor's hosted payment fields, so card data goes directly to the processor and only a token and the last four digits return to HealthLine. The Billing App web server still affects the security of the payment page, so it stays in scope (assessed with a Self-Assessment Questionnaire rather than a full Report on Compliance).

2. Regulatory Terminology (applied)

Term	Definition	In Care Access Navigator
Covered entity (CE)	Health plan, clearinghouse, or provider that transmits health information electronically in standard transactions	HealthLine Regional Medical Center
Business associate (BA) / BAA	A person or vendor that handles PHI on a CE's behalf; bound by a business associate agreement	Cloud/identity providers, the payment processor (for PHI-bearing data), IT vendors
PHI / ePHI	Individually identifiable health information; ePHI is PHI in electronic form	EHR Simulator records, Patient Portal messages, billing statements with diagnosis/visit data
Minimum necessary	Use or disclose only the PHI needed for the purpose	Billing role sees billing data, not clinical notes (Keycloak client scopes)
Required vs addressable	Security Rule specifications that must be implemented vs those implemented if reasonable and appropriate (or documented alternative)	Encryption (§164.312(e)(2)(ii)) is addressable; HealthLine chooses to implement it
Breach / unsecured PHI	Impermissible use or disclosure that compromises PHI, unless a low probability of compromise is shown; unsecured = not encrypted to HHS guidance	Triggers the incident and notification process (Task 5)
Cardholder data (CHD) / PAN	Primary account number plus name, expiry, service code	Entered by patients into processor-hosted fields only
Sensitive authentication data (SAD)	CVV, PIN, full track data — never stored after authorization	Never touches HealthLine systems
Cardholder data environment (CDE)	People, processes and technology that store, process or transmit CHD or can affect its security	Billing App web tier and payment page
SAQ / QSA / ASV	Self-assessment questionnaire / qualified security assessor / approved scanning vendor	Annual SAQ; quarterly external ASV scans

Term	Definition	In Care Access Navigator
Compensating control	Alternative control meeting the intent of a PCI requirement when the original cannot be met	Documented via the controls worksheet if ever used

3. Compliance Requirements Analysis

The analysis uses a standard template (below) and maps each core business process to the data it touches, the systems and roles involved, and the specific HIPAA and PCI DSS requirements that apply. Process owners use it to see exactly which obligations sit in their area.

Document ID	Title	Version	Owner	Approver	Classification
CAN-COMP-RA-001	Compliance Requirements Analysis	1.0	GRC Analyst	Chief Compliance Officer	Internal

Business process map — patient billing and payment

The swimlane shows where ePHI and card data flow, which roles touch them, and the PCI scope boundary (dashed). Steps inside the boundary are subject to PCI DSS; every step that touches ePHI is subject to HIPAA.

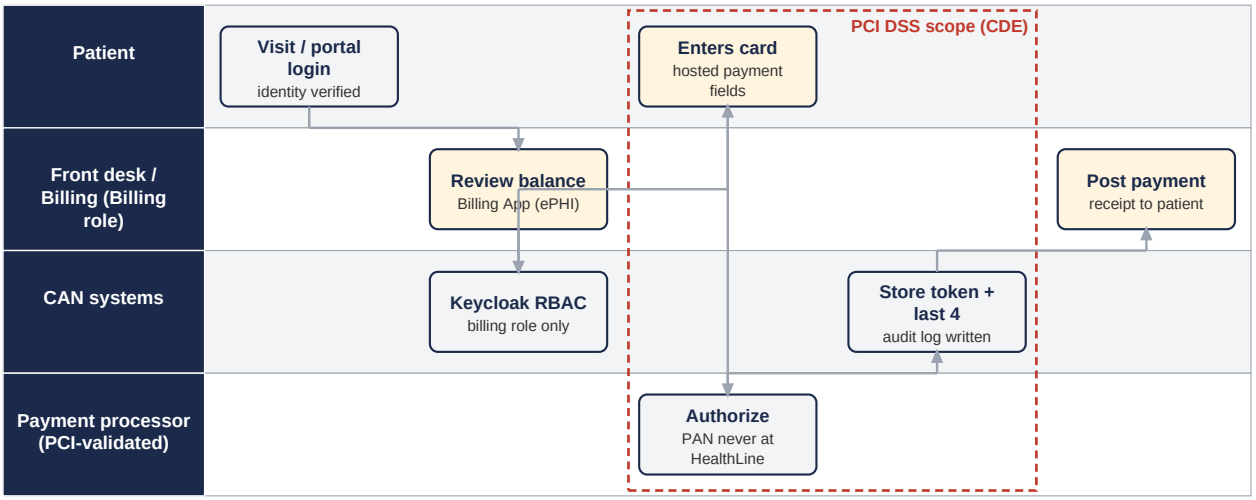

Figure 1. Patient billing and card-payment process with data flows and PCI scope boundary.

Requirements by business process

Business process	Data / systems	Roles	HIPAA requirements	PCI DSS requirements	Owner
Patient identity and portal access	ePHI; Patient Portal, Keycloak	Patient, Clinician, Nurse	§164.312(d) authentication; §164.524 right of access	8.3 authentication (if in CDE)	IAM Analyst

Business process	Data / systems	Roles	HIPAA requirements	PCI DSS requirements	Owner
Clinical documentation	ePHI; EHR Simulator	Clinician, Nurse	§164.312(a)(1) access control; §164.312(b) audit; minimum necessary §164.502(b)	Out of scope	Clinical Ops Mgr
Billing and card payment	ePHI + CHD; Billing App, processor	Billing	§164.506 payment use; §164.312(e)(1) transmission	3.2/3.3 no SAD storage; 4.2.1 TLS; 6.4.3 payment-page scripts; 10.2	Revenue Cycle Mgr
Workforce access lifecycle (JML)	Workforce PII; HR App, Keycloak, Entra ID	HR, IT Support	§164.308(a)(3)(ii)(B)–(C) clearance and termination	7.2.4 6-monthly review; 8.2.6 inactive accounts	HR / IAM Analyst
Vendor and remote access	Varies; Keycloak Vendor role	Vendor, Vendor Mgr	§164.308(b)(1) BAAs; §164.314(a)	8.2.7 vendor remote access enabled only when needed; 12.8 TPSP oversight	Vendor Manager
Security monitoring and incidents	Logs; Azure Monitor, Defender	Security Analyst	§164.308(a)(1)(ii)(D) activity review; §164.308(a)(6)	10.4.1 daily review; 12.10 IR plan	Security Officer

4. Compliance Program Plan

The plan follows the elements of an effective compliance program (written standards, a designated officer and committee, training, monitoring and auditing, reporting channels, enforcement, and response). HIPAA itself requires named privacy and security officials, so those roles are explicit.

Document ID	Title	Version	Owner	Approver	Classification
CAN-COMP-PLN-001	Compliance Program Plan FY2027	1.0	GRC Analyst	Chief Compliance Officer	Internal

4.1 Organizational roles

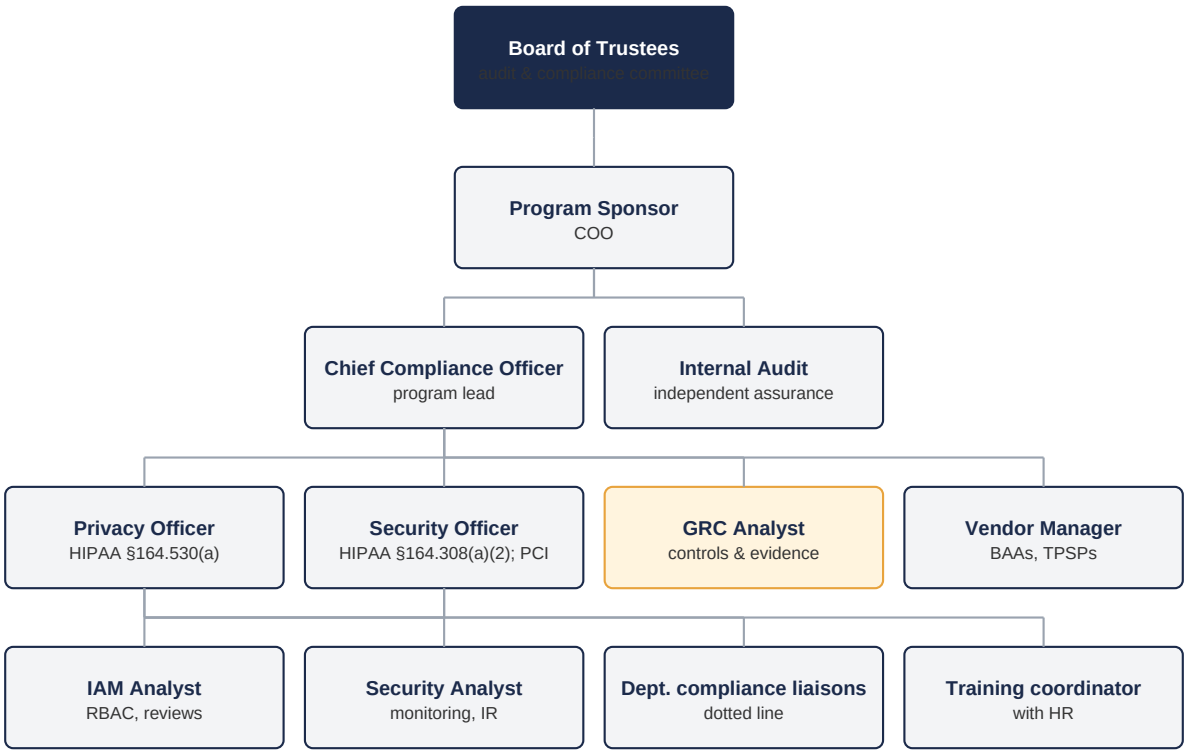

Figure 2. Compliance program organization chart (highlighted: author's role).

Role	Responsibilities
Board of Trustees	Ultimate oversight; approves compliance program charter and annual plan
Program Sponsor (COO)	Executive owner; funds the program; accepts residual High risk
Chief Compliance Officer (CCO)	Runs the compliance program; chairs the Compliance & Privacy Committee
Privacy Officer	HIPAA privacy official (§164.530(a)); breach risk assessments; patient rights
Security Officer (CISO)	HIPAA security official (§164.308(a)(2)); PCI DSS executive responsibility
GRC Analyst	Control matrix, evidence register, audits, compliance reporting
IAM Analyst	Identity, RBAC, access reviews in Keycloak / Entra ID
Security Analyst	Monitoring, alert triage, incident response
Department Managers	Approve access; complete access reviews; enforce training
HR / Workforce Admin	Joiner-mover-leaver events, sanctions, training records
Vendor Manager	Business associate agreements (BAAs); PCI service-provider oversight
Internal Audit	Independent assurance; reports to the Board audit committee

4.2 RACI for core program activities

Activity	CCO	Priv.	Sec.	GRC	IAM	Mgrs	Audit
Annual HIPAA risk analysis	A	C	R	R	C	I	I

Activity	CCO	Priv.	Sec.	GRC	IAM	Mgrs	Audit
Policy development and approval	A	R	R	R	C	C	I
Access reviews (AC-01)	I	I	A	C	R	R	I
Log review and alerting (LOG-01)	I	I	A	C	I	—	I
Workforce training	A	R	R	C	—	R	I
PCI DSS SAQ and ASV scans	A	—	R	R	C	I	C
Breach risk assessment and notification	A	R	C	C	—	I	I
Compliance audits	I	C	C	R	C	C	A

R = responsible, A = accountable, C = consulted, I = informed.

4.3 Implementation timeline

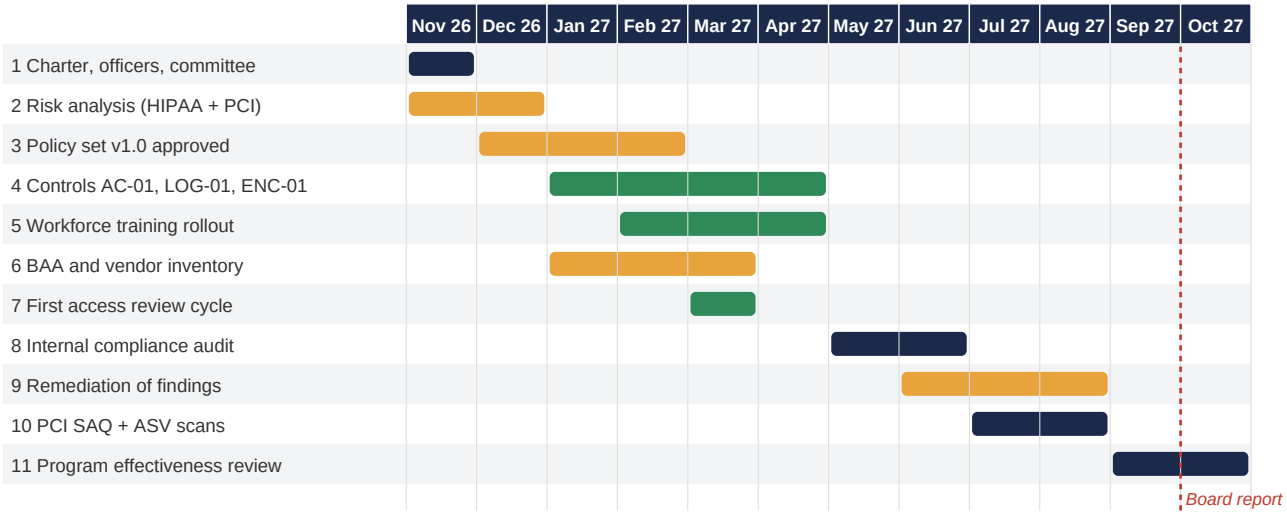

Figure 3. Compliance program implementation timeline, November 2026 – October 2027.

Phase	Window	Exit criteria
Establish	Nov–Dec 2026	Charter signed; officers appointed; committee meeting held; risk analysis started
Design	Dec 2026–Mar 2027	Policy set approved; control owners assigned; BAA inventory complete
Implement	Jan–May 2027	Controls operating; 95% of workforce trained; first access review done
Assure	May–Aug 2027	Internal audit complete; findings in remediation tracker
Improve	Aug–Oct 2027	SAQ submitted; effectiveness review and Board report delivered

5. Documented Compliance Controls

Two controls were selected because they address the highest-rated risks in the capstone risk register (excessive RBAC privileges and logging/monitoring weakness) and satisfy both frameworks at once.

AC-01 Role-based access control and periodic access review

Attribute	Detail
Control objective	Each workforce member receives only the access their job requires, approved by their manager, and access is re-certified at least every six months (quarterly for privileged roles).
HIPAA	HIPAA §164.308(a)(4)(ii)(B)–(C), §164.312(a)(1)
PCI DSS	PCI DSS 7.2.1, 7.2.2, 7.2.4, 7.2.5
Type / frequency	Preventive + detective / continuous with quarterly review
Owner	IAM Analyst (operator); Security Officer (accountable)
Existing evidence	CloudSec1 Criterion 4 addendum (Billing user → billing only; Nurse user → nurse only); audit evidence E-AC-01 (Task 3).

Implementation procedure

1. Define the role catalogue (7 roles) and the data each role may reach; record in the access control matrix.
2. Implement roles in Keycloak; restrict each application with client scopes (fullScopeAllowed = false).
3. Assign roles from the authoritative source: Entra ID app roles map to Keycloak realm roles (Force sync).
4. Require manager approval (ticket) for every new role; HR events drive joiner/mover/leaver changes.
5. Every quarter, export role assignments; managers certify or revoke within 10 business days.
6. IAM Analyst removes revoked access within 2 business days and records the evidence.

Testing methods

Test	Method
Design — inspection	Compare the role catalogue with Keycloak role and client-scope configuration.
Operating — re-performance	Sign in as a test user per role and confirm the token holds only the expected role and the application rejects other areas.
Operating — sampling	Select 25 (or all, if fewer) role changes; confirm a manager approval exists.
Review completion	Confirm the latest access review was signed off and revocations were completed.

LOG-01 Security event logging, alerting and log review

Attribute	Detail
Control objective	Security-relevant events are logged centrally, high-risk events alert the security team automatically, and logs are reviewed daily and retained 12 months (3 months immediately available).
HIPAA	HIPAA §164.312(b), §164.308(a)(1)(ii)(D)
PCI DSS	PCI DSS 10.2.1, 10.4.1, 10.5.1
Type / frequency	Detective / continuous with daily review
Owner	Security Analyst (operator); Security Officer (accountable)
Existing evidence	CloudSec1 Criterion 6 (8 alert rules, incident INC-20261008-01 detected); audit evidence E-LOG-01 (Task 3).

Implementation procedure

1. Enable control-plane logging (Azure Activity Log) and application/IdP event logging (Keycloak events).
2. Forward logs to the central log platform; set retention to 12 months.
3. Create alert rules for firewall changes, privilege grants, key retrieval, policy removal and threat detections; route to the security on-call mailbox.
4. Security Analyst reviews alerts and the daily summary each business day; record the review.
5. Investigate per the incident-response playbook; tune noisy rules monthly.

Testing methods

Test	Method
Design — inspection	Inspect log sources, retention settings and alert-rule definitions.
Operating — re-performance	Generate a benign test event (e.g., a firewall rule change in a lab) and confirm the alert fires and is received.
Operating — sampling	Select 10 business days; confirm a documented log review exists for each.
Retention	Confirm the oldest log available is at least 12 months old (or since go-live).

Summary

HIPAA and PCI DSS both apply to Care Access Navigator; GDPR, SOX and 42 CFR Part 2 were assessed and documented as out of scope. The requirements analysis ties each business process to its obligations and owner, the program plan establishes accountable roles and a twelve-month timeline, and controls AC-01 and LOG-01 are documented with procedures and tests that the Task 3 audit executes against real evidence.